

Executive ISO 27001 & NIST CSF 2.0 Gap Analysis & Risk Remediation Report

Target Organization: PaySecure Cloud Services India Pvt. Ltd.

Assessment Date: October 2026

Target Scope: AWS Production Infrastructure, Kubernetes (EKS) Clusters, Financial APIs, and Customer PII Repositories

Evaluated Frameworks: ISO/IEC 27001:2022 (Annex A), NIST CSF 2.0, Digital Personal Data Protection (DPDP) Act 2023

1. Executive Summary

A comprehensive enterprise information security gap assessment was conducted for PaySecure Cloud Services to evaluate the baseline security posture of its cloud-native fintech platform against **ISO/IEC 27001:2022** and **NIST CSF 2.0**.

The overall calculated compliance score for PaySecure is **50.0% across 9 applicable controls**. Out of 10 total controls evaluated, 1 control (Physical Security) was formally excluded under the AWS Shared Responsibility Model, 2 controls are Fully Implemented, 5 are Partially Implemented, and 2 are Not Implemented.

While baseline operational logging (ISO A.8.15) and vulnerability management (ISO A.8.8) demonstrate strong maturity, **two Critical-risk gaps** pose significant compliance and operational exposure:

1. **DPDP Act 2023 Compliance Breach (A.8.12 / PR.DS-01):** Unencrypted customer PII is accessible in staging/non-production environments without data masking or automated Data Leakage Prevention (DLP).
2. **Business Continuity Failure (A.5.29 / RC.RP-01):** Absence of multi-region database failover testing and unverified RTO/RPO metrics jeopardize the 99.9% uptime SLA for core financial APIs.

2. Enterprise Compliance & Risk Metrics

Table 1: Compliance Status Summary

Metric	Count	Percentage of Applicable Scope	Notes / Status
Total Controls Evaluated	10	100%	Full audit scope covering Cloud, IAM, Data, BCP, & DevSecOps
Applicable Controls (SoA)	9	90.0%	Controls within direct operational boundary
Excluded Controls (SoA)	1	10.0%	Inherited via AWS SOC 2 Type II / ISO 27001 (A.7.1 Physical Security)
Fully Implemented Controls	2	22.2%	Log Stream WORM Storage & Weekly Container CVE Scanning
Partially Implemented Controls	5	55.6%	AWS IaC Baselines, IAM MFA, K8s Image Signing, KMS Keys, SAST
Not Implemented Controls	2	22.2%	Non-prod PII Masking/DLP & Multi-Region DR Failover Testing
Overall Compliance Score	50.0%	—	Calculated as: (Fully Implemented * 1.0 + Partially Implemented * 0.5) / Total Applicable Controls

Table 2: Inherent Risk Profile Breakdown

Inherent Risk Rating	Control Count	Target Remediation Window	Primary Focus Areas
CRITICAL	2	30 Days	Non-prod PII Exposure (A.8.12) & Unverified DR Failover (A.5.29)
HIGH	4	30 to 60 Days	Manual AWS Config (A.5.23), CLI MFA Gaps (A.5.15), Unsigned K8s Containers (A.8.9), Manual SAST (A.8.28)
MEDIUM	1	60 Days	Default KMS Key Management (A.8.24)
LOW	3	90 Days / Maintain	Centralized Logging (A.8.15), Automated CVE Scanning (A.8.8), Physical Security (A.7.1 - Inherited)

3. Detailed Gap Findings & Exposure Analysis

Finding 1: Non-Production PII Exposure & Missing DLP (Critical Risk)

- **Control Mapping:** ISO 27001:2022 A.8.12 | NIST CSF PR.DS-01 | DPDP Act 2023 Sec 8
- **Condition:** Production database staging snapshots containing customer PII (PAN cards, phone numbers, transactional history) are cloned into non-production environments without data masking or tokenization.
- **Impact:** Direct violation of Section 8 of the Indian DPDP Act 2023, exposing PaySecure to regulatory fines up to ₹250 Crore and significant brand reputation damage in the event of a staging environment breach.
- **Remediation:** Enforce dynamic schema-level data masking during database sync pipelines and enable AWS Macie for automated S3 PII detection.

Finding 2: Unverified Business Continuity & Disaster Recovery (Critical Risk)

- **Control Mapping:** ISO 27001:2022 A.5.29 | NIST CSF RC.RP-01
- **Condition:** Multi-region database replication and failover mechanisms have not undergone a live drill or simulation within the past 12 months. RTO and RPO metrics are undocumented in SLA contracts.
- **Impact:** Extended outage during a regional AWS availability zone failure, leading to breached customer SLAs (99.9% uptime requirement) and financial loss during active transaction processing.
- **Remediation:** Define target RTO (4 hours) and RPO (15 minutes), draft a formal BCP/DR Runbook, and execute a scheduled chaos engineering / multi-region failover simulation.

Finding 3: Missing MFA Enforcement on Administrative AWS CLI/API (High Risk)

- **Control Mapping:** ISO 27001:2022 A.5.15 | NIST CSF PR.AA-01
- **Condition:** While AWS Console logins enforce TOTP MFA, programmatic access via AWS CLI/API relies on static Access Keys without mandatory multi-factor session validation.
- **Impact:** Susceptibility to credential theft or developer key leakage, enabling unauthorized full-control execution over cloud management planes.
- **Remediation:** Implement IAM Conditional Access Policies restricting AWS API execution unless authenticated with short-lived session tokens generated via hardware or TOTP MFA.

Finding 4: Unsigned Container Deployments in Kubernetes (High Risk)

- **Control Mapping:** ISO 27001:2022 A.8.9 | NIST CSF PR.PS-01
- **Condition:** Production EKS Kubernetes clusters accept container images directly from public or private registries without cryptographic signature validation.
- **Impact:** Software supply chain vulnerability; malicious or unauthorized container images could be injected into production microservices.
- **Remediation:** Deploy Kyverno or OPA Gatekeeper policy controllers to block unsigned container image execution in production namespaces.

4. 30-60-90 Day Remediation Roadmap

Phase 1: Immediate Risk Reduction (0 - 30 Days)

- Implement Dynamic PII Data Masking in Non-Prod Staging
- Enforce Mandatory Hardware/TOTP MFA on AWS CLI/API Session Credentials
- Conduct Multi-Region DR Failover Simulation & Document RTO/RPO

Phase 2: Secure Architecture & Guardrails (31 - 60 Days)

- Deploy Terraform Infrastructure as Code (IaC) Baselines & GuardDuty
- Enforce Container Image Signature Verification via Kyverno on EKS
- Transition Cloud Encryption to Customer Managed Keys (CMK) with 90-Day Rotation
- Integrate SAST Scans (SonarQube/Semgrep) into GitHub Actions Build Pipelines

Phase 3: Continuous Governance & Optimization (61 - 90 Days)

- Establish Automated Compliance Monitoring & Drift Alerts
- Perform Annual Third-Party Vendor SOC 2 / ISO Certification Review
- Prepare Final ISO 27001 Annex A Audit Evidence Package

Table 3: Actionable Remediation Plan

Milestone	Action Item	Target Control	Primary Owner	Resource / Tooling Required
30 Days	Deploy dynamic schema masking for database staging clones.	ISO A.8.12 / DPDP	Database Admin	PostgreSQL Masking / AWS Macie
30 Days	Enforce conditional IAM policies requiring MFA for AWS CLI keys.	ISO A.5.15	IAM / SecOps	AWS IAM Conditional Policies
30 Days	Conduct multi-region	ISO A.5.29	Infrastructure	AWS Aurora Global DB /

	database failover drill and publish RTO/RPO.			Route 53
60 Days	Convert console-built AWS resources into Terraform IaC templates.	ISO A.5.23	DevOps	HashiCorp Terraform
60 Days	Block unsigned container image deployments in production EKS.	ISO A.8.9	DevSecOps	Cosign / Kyverno Admission Control
60 Days	Shift KMS from AWS-managed keys to Customer Managed Keys (CMK).	ISO A.8.24	SecOps	AWS KMS
60 Days	Embed SAST security gates directly into GitHub Actions pipelines.	ISO A.8.28	Engineering	SonarQube / Semgrep CI/CD
90 Days	Execute quarterly log retention and SIEM WORM lock audit.	ISO A.8.15	SOC Lead	AWS S3 Object Lock / SIEM
90 Days	Review third-party	ISO A.7.1	Compliance Lead	AWS Artifact Governance

	AWS SOC 2 Type II reports for physical controls.			Portal
--	---	--	--	--------

5. Strategic Governance & Compliance Recommendations

1. **Adopt Security-as-Code Guardrails:** Transition away from manual cloud management by requiring all cloud provisioning to pass through code-reviewed Infrastructure as Code (IaC) pipelines with static security scanning (Checkov / TFSec).
2. **Institute Continuous Compliance Monitoring:** Implement continuous compliance scoring tools (AWS Audit Manager / Security Hub) mapped directly to ISO 27001:2022 Annex A and NIST CSF 2.0 to maintain real-time visibility into control status.
3. **Establish Monthly CISO Steering Reviews:** Track the execution of the 30-60-90 day remediation roadmap during monthly executive risk reviews to ensure zero overdue critical or high findings prior to formal ISO 27001 certification auditing.